

# LAB: Static/Dynmaic Analysis

4/18/26      4:18 PM

## Overall Malware Analysis Workflow

1. **Static** → Strings + Hash + VT (quick IOCs, no risk).
2. **Dynamic** → Regshot snapshots (see real changes).
3. **Decomposition** → IDA disassembly (understand code logic and APIs).

### Safety First:

- Always use isolated VM with snapshots.
- Never run on production systems.
- Document everything (hash, behavior, changes).

### Key Takeaways:

- Static = safe & fast.
- Dynamic = reveals actual impact.
- Disassembly = deepest code-level understanding.
- Combine all three for complete picture.

## 1. Static Analysis (Without Running the Malware)

**What it is:** Examine the file as-is to extract strings, hashes, imports, and basic indicators.

**Why it matters:** Fast, safe, no risk of infection. Good first step to decide if deeper analysis is needed.

### Key Tools & Commands:

- **strings** (strings64.exe on Windows):  
cmd  
`strings Formbook.exe > strings.txt`
  - Extracts printable ASCII/Unicode strings.
  - Look for: DLL names, function imports, URLs, file paths, registry keys, embedded executables (e.g., pRue.exe).
- **certutil** (built-in Windows):  
cmd  
`certutil -hashfile sample.exe SHA256`
  - Generates unique file hash (SHA256 recommended).
- **VirusTotal:**
  - Search by hash.
  - Check tabs: **Behavior** (file drops, network activity), **Network Communication** (C2 domains/IPs), **File System Actions** (created/modified files).

### What to Look For:

- Suspicious strings (DLLs, .exe names, URLs).
- Hash for threat intelligence.
- Behavioral summary from VT (even before running it).

**Interview tip:** “Static analysis gives quick IOCs and strings without execution risk.”

## 2. Dynamic Analysis (Observe Changes While Running)

**What it is:** Run the malware in a controlled environment and compare system state before/after.

**Why it matters:** Reveals exact changes (registry, files, processes) that static analysis misses. Shows real behavior.

**Key Tool: Regshot** (simple before/after snapshot):

### Steps:

1. Take **1st Shot** (baseline of clean system).
2. Run malware (as admin if needed).
3. Wait for execution.
4. Take **2nd Shot**.
5. **Compare** → generates report.

### What the Report Shows:

- **Keys added / Values added:** New registry entries (persistence).
- **Values deleted / Values modified:** Changes to existing settings.
- **Total changes:** Overall impact summary.

### Reusable Tips:

- Always run in isolated VM with snapshot.
- Focus on registry (Run keys, services) and file drops.
- Compare multiple runs — behavior can vary.

**Interview tip:** “Dynamic analysis with snapshot tools like Regshot shows precise filesystem and registry changes caused by malware.”

## 3. Malware Decomposition / Disassembly

**What it is:** Break the executable into assembly instructions to understand its low-level logic.

**Why it matters:** Reveals exact code flow, functions, and hidden behavior (especially in packed or obfuscated samples).

**Key Tool: IDA Free** (Interactive Disassembler):

### Basic Workflow:

1. Load the executable (File → New).
2. Let IDA analyze (auto-disassembly).
3. Explore views:
  - **Functions window:** List of functions (start with start or main).
  - **Disassembly view:** Assembly instructions (pin to keep visible).
  - **Hex View:** Raw bytes/hex of the code.
  - **Imports tab:** DLLs and API functions the malware calls (critical for understanding capabilities).
  - **Exports tab:** Functions exported by the sample (less common in malware).

### What to Look For:

- Imported APIs (e.g., network, registry, process creation).
- Entry point and main logic flow.
- Strings or constants that were hidden in static strings output.

### Reusable Tips:

- Start with Imports tab — tells you what the malware *can* do.
- Look for suspicious calls (CreateProcess, InternetConnect, RegSetValue).
- Use for packed malware: unpack first, then disassemble the unpacked binary.

**Interview tip:** “Disassembly with IDA shows the exact assembly instructions and imported APIs, giving deep insight into malware capabilities without full execution.”